

Федеральное государственное автономное образовательное учреждение
высшего образования «Национальный исследовательский университет
ИТМО»

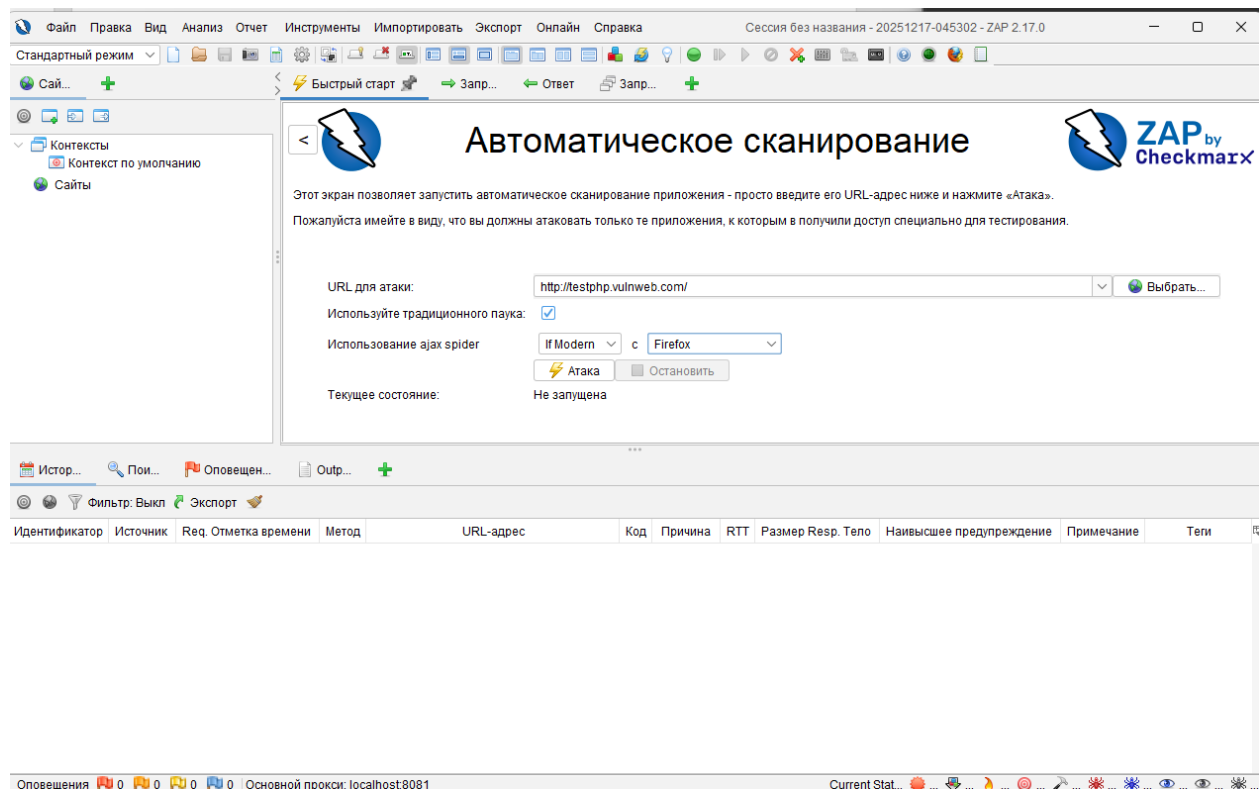
Отчёт
по лабораторной работе №4
по дисциплине
«Информационная безопасность»

Выполнил:
студент 4-го курса
Батманов Даниил Евгеньевич
Группа:
Р3407

г. Санкт-Петербург, 2025

Подготовка

Я установил OWASP ZAP, запустил браузер и запустил «Быстрое сканирование» сайта из примера (<http://testphp.vulnweb.com/>).



После сканирования я получил 11 алертов, они сразу отранжированы по степени критичности (степени риска).

- ▼ Оповещения (11)
 - > Заролюнок Content Security Policy (CSP) не задан (Systemic)
 - > Отсутствует заголовок (Header) для защиты от клидджекинга (Systemic)
 - > **Отсутствуют токены против CSRF атак (Systemic)**
 - > In Page Banner Information Leak (3)
 - > Заролюнок X-Content-Type-Options отсутствует (Systemic)
 - > Сервер утекает информацию через поля заголовка HTTP-ответа "X-Powered-By" (Systemic)
 - > Сервер утечка информации о версии через поле заголовка HTTP-ответа «Server» (Systemic)
 - > Authentication Request Identified
 - > Charset Mismatch (Header Versus Meta Content-Type Charset) (Systemic)
 - > Атрибут элемента HTML, управляемый пользователем (потенциальный XSS) (2)
 - > Современное веб-приложение (Systemic)

Анализ результатов сканирования

Уязвимость: Потенциальный Cross-Site Scripting (XSS) через управляемый пользователем атрибут HTML

- Уровень риска: Средний (Medium)
- Механизм: ZAP обнаружил, что данные, введенные пользователем (например, в форму поиска), напрямую подставляются в атрибуты HTML-тегов (вроде value="пользовательский_ввод") без должной проверки и очистки.
- Суть проблемы: Злоумышленник может ввести специально сформированную строку, которая "сломает" атрибут и добавит в страницу новый, вредоносный атрибут (например, onmouseover="злой_код") или целый тег <script>.
- Возможные последствия: При посещении такой "отравленной" страницы в браузере жертвы выполняется скрипт злоумышленника. Это может привести к краже файлов cookie (и сессии), перенаправлению на фишинговый сайт или выполнению действий от имени пользователя.
- Рекомендация по устранению: Внедрить строгую валидацию и экранирование (HTML-encoding) всех пользовательских данных перед их вставкой в HTML-код. Использовать безопасные API для работы с DOM.

Заголовок Content Security Policy (CSP) не задан

URL-адрес: <http://testphp.vulnweb.com/>

Риск:  Medium

Достоверность: High

Параметр:

Атака:

Доказательства:

CWE ID: 693

WASC ID: 15

Источник: Пассивный (10038 - Заголовок Content Security Policy (CSP) не задан)

Alert Reference: 10038-1

Input Vector:

Описание:

Политика безопасности содержимого (CSP) — это дополнительный уровень безопасности, который помогает обнаруживать и смягчать определенные типы атак, включая межсайтовые сценарии (XSS) и атаки с внедрением данных. Эти атаки используются для всего: от кражи данных до порчи сайта или распространения вредоносных программ. CSP предоставляет набор стандартных HTTP-заголовков, которые позволяют владельцам веб-сайтов объявлять

Дополнительно:

Решение:

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Уязвимость: Утечка информации через внутренние баннеры (In Page Banner Information Leak)

- Уровень риска: Низкий (Low)
- Механизм: В HTML-коде веб-страниц обнаружены технические комментарии, сообщения об ошибках или баннеры, оставленные разработчиками. Они содержат внутреннюю информацию.
- Суть проблемы: Подобная информация (пути к файлам, версии библиотек, имена папок) не предназначена для глаз пользователей. Она раскрывает структуру приложения и используемый софт.

- **Возможные последствия:** Эта информация служит "картой" для атакующего. Зная точные версии компонентов, он может быстро найти и эксплуатировать известные для них уязвимости (например, через базы данных вроде CVE). Пути к файлам могут наметить на расположение конфиденциальных данных.
- **Рекомендация по устранению:** Перед развертыванием приложения на боевом сервере необходимо провести аудит кода и удалить все технические комментарии, отладочные сообщения и информационные баннеры. Настройки фреймворков и серверов должны быть переведены в "production-режим", который скрывает детальные ошибки.

In Page Banner Information Leak	
URL-адрес:	http://testphp.vulnweb.com/robots.txt
Риск:	Low
Достоверность:	High
Параметр:	
Атака:	
Доказательства:	nginx/1.19.0
CWE ID:	497
WASC ID:	13
Источник:	Пассивный (10009 - In Page Banner Information Leak)
Input Vector:	
Описание:	The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.
Дополнительно:	There is a chance that the highlight in the finding is on a value in the headers, versus the actual matched string in the response body.
Решение:	Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.
Ссылка:	https://www.exploit-db.com/exploits/4444/Mob-Apache-Security-Testing/00-Testing-for-Error-Headers/

Уязвимость: Раскрытие технологического стека через заголовок X-Powered-By

- **Уровень риска:** Низкий (Low) / Информационный (Informational)
- **Механизм:** Веб-сервер или бэкенд-приложение автоматически добавляет в каждый HTTP-ответ заголовок X-Powered-By: PHP/5.4.1 (пример).
- **Суть проблемы:** Заголовок добровольно сообщает атакующему, какая именно технология и её версия работают на сервере.
- **Возможные последствия:** Атакующий получает точный вектор для атаки. Вместо слепого перебора методов, он может целенаправленно искать эксплойты для конкретной версии PHP, ASP.NET, Tomcat и т.д., что значительно повышает шансы на успешный взлом.
- **Рекомендация по устранению:** Настроить веб-сервер (Apache, Nginx) или приложение (например, в php.ini или настройках фреймворка) на удаление или перезапись информативных заголовков. Цель — отправлять минимально необходимый набор заголовков.

Сервер утекает информацию через поля заголовка HTTP-ответа "X-Powered-By"

URL-адрес: <http://testphp.vulnweb.com/>

Риск:  Low

Достоверность: Medium

Параметр:

Атака:

Доказательства: X-Powered-By: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1

CWE ID: 497

WASC ID: 13

Источник: Пассивный (10037 - Сервер утекает информацию через поля заголовка HTTP-ответа "X-Powered-By")

Input Vector:

Описание:

Веб-сервер / сервер приложений пропускает информацию через один или несколько заголовков HTTP-ответа «X-Powered-By». Доступ к такой информации может облегчить злоумышленникам идентификацию других фреймворков / компонентов.

Дополнительно:

Решение:

Убедитесь, что ваш веб-сервер, сервер приложений, балансировщик нагрузки и т. д. настроены на подавление заголовков «X-Powered-By».

Ссылка:

https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework

Уязвимость: Отсутствие защиты от MIME-sniffing (заголовок X-Content-Type-Options)

- Уровень риска: Низкий (Low) / Информационный (Informational)
- Механизм: Сервер не отправляет в ответах HTTP-заголовок X-Content-Type-Options: nosniff.
- Суть проблемы: Некоторые браузеры (в попытке "помочь") могут анализировать содержимое файла (MIME-sniffing), чтобы определить его тип, даже если сервер уже указал его в заголовке Content-Type. Например, текстовый файл, содержащий HTML-код, может быть обработан как HTML-страница.
- Возможные последствия: Это поведение может быть использовано для атак с подменой содержимого. Злоумышленник может загрузить на сайт вредоносный скрипт под видом изображения (.jpg), и если браузер выполнит sniffing и обработает его как скрипт, это может привести к XSS.
- Рекомендация по устранению: Добавить заголовок X-Content-Type-Options: nosniff для всех ответов сервера, особенно для ресурсов, которым пользователи могут доверять (стили, скрипты). Это делается в конфигурации веб-сервера.

Заголовок X-Content-Type-Options отсутствует	
URL-адрес:	http://testphp.vulnweb.com/
Риск:	 Low
Достоверность:	Medium
Параметр:	x-content-type-options
Атака:	
Доказательства:	
CWE ID:	693
WASC ID:	15
Источник:	Пассивный (10021 - Заголовок X-Content-Type-Options отсутствует)
Input Vector:	
Описание:	Для заголовка Anti-MIME-Sniffing X-Content-Type-Options не задано значение «nosniff». Это позволяет более старым версиям Internet Explorer и Chrome выполнять MIME-сниффинг тела ответа, что может привести к интерпретации и отображению тела ответа как тип контента,
Дополнительно:	Эта проблема по-прежнему относится к страницам с типами ошибок (401, 403, 500 и т. д.), Поскольку на эти страницы часто по-прежнему влияют проблемы с внедрением, и в этом случае по-прежнему существует проблема, связанная с тем, что браузеры отслеживают страницы с их фактическим типом содержимого.
Решение:	Убедитесь, что приложение / веб-сервер правильно задает заголовок Content-Type и что он устанавливает заголовок X-Content-Type-Options равным «nosniff» для всех веб-страниц. Если возможно, убедитесь, что конечный пользователь использует современный веб-браузер, соответствующий стандартам, который вообще не выполняет
Ссылка:	

Уязвимость: Отсутствие защиты от клиджекинга (Clickjacking)

- Уровень риска: Средний (Medium) / Информационный (Informational)
- Механизм: Сервер не отправляет заголовки, предотвращающие встраивание сайта в <iframe> (или отправляет их с нестрогими значениями).
- Суть проблемы: Атакующий может разместить целевой сайт в прозрачном или замаскированном <iframe> на своей вредоносной странице. Пользователь, думая, что кликает по кнопкам на странице злоумышленника, на самом деле взаимодействует со скрытым iframe, выполняя действия на целевом сайте (например, подтверждая перевод денег, меняя пароль).
- Возможные последствия: Обман пользователя и выполнение несанкционированных действий от его имени на уязвимом веб-приложении (например, в социальной сети или интернет-банке).
- Рекомендация по устранению: Настроить отправку HTTP-заголовка X-Frame-Options: DENY (запрещает любое встраивание) или SAMEORIGIN (разрешает встраивание только с того же домена). Более современной альтернативой является использование политики frame-ancestors в заголовке Content-Security-Policy (CSP).

Отсутствует заголовок (Header) для защиты от клидджекинга

URL-адрес: http://testphp.vulnweb.com/

Риск: 🟡 Medium

Достоверность: Medium

Параметр: x-frame-options

Атака:

Доказательства:

CWE ID: 1021

WASC ID: 15

Источник: Пассивный (10020 - Заголовок против клидджекинга)

Alert Reference: 10020-1

Input Vector:

Описание:

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Дополнительно:

Решение:

Современные веб-браузеры поддерживают Content-Security-Policy и заголовки HTTP X-Frame-Options. Убедитесь, что один из них установлен на всех веб-страницах, возвращаемых вашим сайтом/приложением. Если вы ожидаете, что страница будет обрамлена только страницами на вашем сервере (например, это